

Section A: Scenario-Based Concept Application

1. Verification: Multi-Factor Verification Process

To distinguish a legitimate password reset from a credential harvesting attempt:

1. User initiates password reset from the official website.
2. System sends a verification code via email, SMS, or authenticator app.
3. User must verify identity using MFA (OTP, security key, biometric, etc.).
4. The website URL should be verified for HTTPS and correct domain name.
5. Password reset notifications are sent to registered contact methods.
6. Risk-based authentication checks:
 - a. Device fingerprint
 - b. Geolocation
 - c. IP reputation
 - d. Login behavior

Credential harvesting signs:

- Unexpected password reset emails.
- Fake login pages.
- URL mismatches.
- Requests for MFA codes by email or phone.

2. Header Analysis: SMTP Fields

Important SMTP header fields:

Header Field	Purpose
From	Visible sender address
Reply-To	Address where replies are sent

Return-Path Bounce address

Received Mail server path

Message-ID Unique email identifier

Suspicious Example:

From: support@company.com

Reply-To: attacker@gmail.com

Mismatch indicates potential phishing.

Check:

From:

Reply-To:

Return-Path:

Received:

3. Spoofing Logic: Display Name Spoofing

Display name spoofing occurs when attackers use trusted names:

Microsoft Support <attacker@evil.com>

CEO John Smith <fraud@evil.com>

Users often see only:

Microsoft Support

Even if SPF and DKIM pass for the attacker's domain, users may trust the display name.

Example:

PayPal Security <secure@phishing-site.com>

Technical authentication passes, but social engineering succeeds.

4. Defense-in-Depth: Human Firewall

User awareness acts as the first line of defense.

Technical controls:

- Spam filtering
- Email gateways
- SPF
- DKIM
- DMARC
- Sandboxing

Human firewall activities:

- Identifying suspicious emails
- Reporting phishing attempts
- Verifying URLs
- Avoiding suspicious attachments

Benefits:

- Reduces successful attacks

- Supports incident detection
- Improves organizational security culture

5. Incident Response After Clicking Malicious Link

Immediate actions:

1. Disconnect affected host from network.
2. Disable Wi-Fi and VPN connections.
3. Notify SOC or security team.
4. Revoke user credentials.
5. Reset password.
6. Terminate active sessions.
7. Revoke MFA tokens if possible.
8. Scan endpoint for malware.
9. Review logs.
10. Monitor account activity.

Goal: prevent lateral movement and data theft.

6. NIST CSF Category

User awareness training belongs to:

Protect (PR)

Category:

PR.AT – Awareness and Training

Subcategories:

- PR.AT-1
- PR.AT-2
- PR.AT-3
- PR.AT-4
- PR.AT-5

Purpose:

- Educate employees against phishing and social engineering.

Section B: Practical Application

1. Simulation Using SET

The Social Engineering Toolkit can be used only in an authorized lab environment.

General workflow:

```
sudo setoolkit
```

Menu:

- 1) Social Engineering Attacks
- 2) Website Attack Vectors
- 3) Credential Harvester Attack Method
- 4) Web Templates

The tool creates a simulated phishing page for awareness testing and training.

2. Forensics: Analyze .eml File

Open email:

```
nano phishing.eml
```

or

```
less phishing.eml
```

Look for:

Received:

Return-Path:

From:

Reply-To:

Extract originating IP:

```
grep "Received:" phishing.eml
```

Blacklist lookup:

```
host 192.168.1.100
```

or

```
whois <IP>
```

Check using blacklist services such as MXToolbox.

3. DNS Validation (SPF and DMARC)

Check SPF:

```
dig TXT example.com
```

Expected:

```
v=spf1 include:_spf.google.com ~all
```

Check DMARC:

```
dig TXT _dmarc.example.com
```

Example:

```
v=DMARC1; p=reject;
```

Using nslookup:

```
nslookup -type=TXT example.com
```

```
nslookup -type=TXT _dmarc.example.com
```

4. Proxy Log Identification

Sample log:

192.168.1.50 POST <http://evil-login.com/login.php> 200

Identify:

- POST method
- External domain
- Success status (200)

Linux command:

```
grep "POST" proxy.log
```

or

```
grep "POST.*200" proxy.log
```

5. Mail Flow Rule

Example configuration:

Condition:

Sender is outside organization

Action:

Prepend disclaimer

Text:

WARNING: External Email

Verify sender before opening links or attachments.

Benefits:

- Improves phishing awareness.
- Provides visual warning.

Section C: Integrated Case Study

Scenario: Apex Financial Spear-Phishing Attack

1. Detection

Indicators suggesting MFA session token theft:

1. Attacker gains access despite MFA.
2. Login occurs immediately after victim authentication.
3. Successful login from unusual IP address.
4. No MFA challenge triggered.
5. Multiple active sessions detected.
6. Access occurs within minutes of phishing event.

This indicates an Adversary-in-the-Middle (AitM) attack capturing session cookies or refresh tokens.

2. Containment

Steps:

1. Disable affected account.
2. Force password reset.
3. Revoke active sessions.
4. Revoke OAuth tokens.
5. Revoke refresh tokens.
6. Require fresh MFA registration.
7. Remove unauthorized devices.

8. Monitor logs for reauthentication attempts.

Examples:

Microsoft 365

Revoke-AzureADUserAllRefreshToken

Google Workspace

Admin Console

→ Security

→ User

→ Sign Out User

3. NIST Respond (RS.RP)

Category:

RS.RP – Response Planning

Required actions:

1. Document timeline of attack.
 - a. Initial phishing email
 - b. Credential submission
 - c. Unauthorized access
 - d. Data exfiltration
2. Record:
 - a. Affected systems
 - b. Compromised accounts
 - c. Data accessed
 - d. Containment measures

Purpose:

- Support recovery and future improvements.

4. Technical Solution

Recommended:

FIDO2/WebAuthn Security Keys

Examples:

- YubiKey
- Google Titan Security Key

Benefits:

- Cryptographic challenge-response.
- Bound to legitimate domain.
- Resistant to phishing.
- Blocks proxy-based credential theft.
- No shared secrets.

Even if attacker clones the website, authentication fails because the security key verifies the real domain.

5. Policy Design

Automated technical control:

Conditional Access / Device Compliance Policy

Requirements:

1. Device must be company-managed.
2. Endpoint protection installed.
3. Disk encryption enabled.
4. Latest security patches applied.
5. Device enrolled in MDM.

Examples:

- Microsoft Intune
- VMware Workspace ONE

Policy Rule:

Allow login:

IF Device = Compliant

Deny login:

IF Device = Unmanaged